ASA AI

DOCUMENT D'INGÉNIERIE • SÉCURITÉ VOIP

AI Security Audit Report

AI agents, workflows and LLM models — Example Organisation Ltd (fictitious)

Reference ASA-AUD-2026-EX01 • Report version 1.0 • Confidential

Auditor: ASA AI — Lead auditor (example)

Report date: 01/10/2026 • January to September 2026

ISO 19011:2018 • NIST SP 800-53A • ISO/IEC 42001:2023 • ISO/IEC 23894:2023 • ISO/IEC 27001:2022 • CSA AICM • NIST AI RMF 1.0 • NIST AI 600-1 • OWASP Top 10 LLM



This page is intentionally left blank

Contents

1. Executive summary 5

1.1 Overall opinion 5
1.2 Key indicators 5
1.3 Main risks 5
1.4 Priority recommendations 5

2. Engagement 6

2.1 Engagement identification 6
2.2 Stakeholders 6
2.3 Schedule 6
2.4 Objectives 7
2.5 Scope and exclusions 7

3. Frameworks and audit criteria 8

3.1 Selected frameworks 8
3.2 Domains assessed 8

4. Methodology 10

4.1 Audit principles (ISO 19011) 10
4.2 Verification methods (NIST SP 800-53A) 10
4.3 Rating scale 10
4.4 Risk assessment 10
4.5 Interviews and documents reviewed 11
4.6 Assumptions and limitations 11

5. Overall results 12

5.1 Figures at a glance 12
5.2 Breakdown of answers and risks 12
5.3 Compliance by domain 12
5.4 Compliance by framework 13
5.5 Residual risk matrix 13

6. Detailed results by domain 14

6.1 AI governance and organisation 14
6.2 Inventory of AI use and shadow AI 14
6.3 LLM models and supply chain 15
6.4 Data and privacy 15
6.5 Prompts, inputs / outputs and RAG 16
6.6 AI agents and autonomy 17
6.7 AI workflows and integrations (MCP, API, A2A) 17
6.8 Testing, red teaming and evaluation 18
6.9 Monitoring, logging and incidents 18
6.10 Regulation and compliance 19

7. Risk register and action plan 20

7.1 Risk register 20
7.2 Action plan 22

8. Conclusion 25

Contents (continued)

8.1 Auditor's conclusion 25
8.2 Next steps 25
9. Approval and distribution 26
9.1 Approval 26
9.2 Distribution list 26
Appendices 27
Appendix A — Organisation profile 27
Appendix B — Glossary 27
Appendix C — Disclaimer 27

1. Executive summary

1.1 Overall opinion

> The set-up is defined and covers a significant share of the requirements. Material gaps remain in some domains. Implementing the action plan would bring the organisation to a managed level.

Incomplete questionnaire: 8 applicable question(s) without an answer are excluded from the calculation.

1.2 Key indicators

OVERALL COMPLIANCE	COMPLETION	MATURITY LEVEL	CRITICAL / HIGH RISKS
58%	92%	2 · Defined	12 / 15

1.3 Main risks

ID	Question	Answer	Risk	Level
AGT-03	Are agent permissions limited to the strict minimum for each task?	No	20	Critical
AGT-04	Do high-impact actions (payment, deletion, external sending) require human approval?	No	20	Critical
WFL-01	Are MCP servers, APIs and tools connected to agents inventoried and approved?	Don't know	20	Critical
WFL-04	Are parameters sent to tools validated before execution?	Don't know	20	Critical
AGT-10	Are agent goals and plans monitored to detect hijacking?	Don't know	20	Critical

1.4 Priority recommendations

- AI workflows and integrations (MCP, API, A2A) (33%): Inventory and approve connected tools, scope tokens and validate parameters sent to tools.
- Monitoring, logging and incidents (47%): Log every AI action in a tamper-proof way, send it to the SOC and prepare incident response.
- AI agents and autonomy (50%): Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.
- Testing, red teaming and evaluation (53%): Run regular attack testing covering OWASP risks, plus automated evaluations.

2. Engagement

2.1 Engagement identification

Reference	ASA-AUD-2026-EX01
Audit type	External (third-party) audit
Report version	1.0
Classification	Confidential
Report date	01/10/2026
Language	English

2.2 Stakeholders

Legal name	Example Organisation Ltd (fictitious)
Industry	Financial services
Address	Paris, France
Identifier (company or VAT number)	Not specified
Headcount	850
Sponsor (name, title)	Chief Information Security Officer
Main contact (name, title, e-mail)	AI programme lead

Audit firm	ASA AI
Lead auditor (name, title)	Lead auditor (example)
Auditor certifications	ISO/IEC 42001 Lead Auditor, ISO/IEC 27001 Lead Auditor
Audit team and experts	1 lead auditor, 1 AI security expert
Auditor contact	contact@asa-ai.fr

The audit team declares no conflict of interest with the audited scope.

2.3 Schedule

Opening meeting	14/09/2026
Fieldwork start	14/09/2026
Fieldwork end	25/09/2026
Closing meeting	29/09/2026
Report date	01/10/2026
Period covered by the audit	January to September 2026

2.4 Objectives

Assess the security and governance level of AI systems (agents, workflows, language models) against the selected frameworks, identify gaps and residual risks, and propose a prioritised action plan.

2.5 Scope and exclusions

Head office IT department; customer support and internal assistant services

AI systems audited

- Internal assistant (RAG on document base)
- Customer support agent (ticketing and CRM tools)
- Code assistant for developers

Exclusions

Subsidiaries outside France; AI features of office software not activated

Organisation profile: see Appendix A.

3. Frameworks and audit criteria

3.1 Selected frameworks

Framework	Subject
ISO 19011:2018	Guidelines for auditing management systems: principles, audit conduct, auditor competence.
NIST SP 800-53A Rev. 5	Assessing security controls: examine, interview and test methods.
ISO/IEC 42001:2023	Artificial intelligence management system.
ISO/IEC 23894:2023	Guidance on AI risk management.
ISO/IEC 27001:2022	Information security management system.
CSA AI Controls Matrix (AICM)	Cloud Security Alliance AI security controls matrix.
NIST AI RMF 1.0 (AI 100-1)	AI risk management framework: Govern, Map, Measure, Manage.
NIST AI 600-1	Generative AI profile of the NIST AI RMF.
OWASP Top 10 for LLM Applications 2025	Top ten risks of LLM applications.
OWASP Top 10 for Agentic Applications	Top ten risks specific to AI agents (ASI01 to ASI10).
MITRE ATLAS	Knowledge base of attack tactics and techniques against AI systems.
Règlement (UE) 2024/1689 — AI Act	European regulation on artificial intelligence.
Règlement (UE) 2016/679 — RGPD / GDPR	Personal data protection.
ANSSI — Recommandations de sécurité pour un système d'IA générative (2024)	Recommendations of the French national cybersecurity agency.

3.2 Domains assessed

Domain	Questions	Applicable	Main related frameworks
AI governance and organisation	12	12	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act
Inventory of AI use and shadow AI	8	8	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
LLM models and supply chain	12	8	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Data and privacy	12	10	OWASP LLM, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Prompts, inputs / outputs and RAG	12	12	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
AI agents and autonomy	14	14	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, AI Act, MITRE ATLAS
AI workflows and integrations (MCP, API, A2A)	12	12	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, MITRE ATLAS
Testing, red teaming and evaluation	10	10	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Monitoring, logging and incidents	12	11	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act
Regulation and compliance	10	6	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act

Indicative mappings: they guide the analysis and do not replace reading the official texts.

4. Methodology

4.1 Audit principles (ISO 19011)

- Integrity: Perform work with honesty, diligence and responsibility.
- Fair presentation: Report findings truthfully, including disagreements.
- Due professional care: Apply judgement suited to the importance of the engagement.
- Confidentiality: Protect information obtained during the audit.
- Independence: Remain impartial and objective towards the audited scope.
- Evidence-based approach: Base conclusions on verifiable evidence.
- Risk-based approach: Focus effort on what matters most.

4.2 Verification methods (NIST SP 800-53A)

Verification method	Subject	Used	Answers
Document review	Examine policies, procedures, configurations, logs.	Yes	40
Interview	Interview owners and teams.	Yes	42
Technical test	Test how the control actually works.	Yes	23
Observation	Observe an activity or process in progress.	No	0

4.3 Rating scale

Answer	Meaning
Yes	Control in place, applied and evidenced
Partial	Control exists but is incomplete or not applied everywhere
No	Control absent
Don't know	Information unavailable: treated as a gap
N/A	Not applicable (profile or justification)

Score	Yes = 100% of weight, Partial = 50%, No and Don't know = 0. N/A and unanswered questions are excluded.
Weight	1 useful • 2 important • 3 essential.
Risk	Impact (1-5) × residual likelihood (1-5). Residual likelihood: 1 if Yes, base - 2 if Partial (minimum 1), base if No or Don't know.
Level	Critical ≥ 15 • High 10-14 • Medium 5-9 • Low < 5.
Maturity	0 Initial (< 20%) • 1 Exploratory (< 40%) • 2 Defined (< 60%) • 3 Managed (< 80%) • 4 Optimised (≥ 80%).

4.4 Risk assessment

Each question carries an impact (1 to 5) and a base likelihood (1 to 5). Residual likelihood depends on the answer: 1 if Yes, base minus 2 if Partial (minimum 1), base if No or Don't know. Residual risk is impact times residual likelihood (1 to 25): Critical from 15, High from 10 to 14, Medium from 5 to 9, Low below 5. The compliance score weights each question (1 to 3): Yes counts 100%, Partial 50%, No and Don't know 0%.

4.5 Interviews and documents reviewed

People interviewed

- CISO (14/09)
- AI programme lead (15/09)
- Head of development (16/09)
- SOC manager (17/09)
- Data protection officer (18/09)

Documents reviewed

- AI use policy v1.2
- AI system register
- Risk analyses of the 3 systems
- Vendor contracts
- Logging and SIEM configuration

Tools used

- Prompt injection test suite, configuration review scripts

Sampling

- All 3 AI systems in scope; 20 agent actions sampled per system

4.6 Assumptions and limitations

Technical tests limited to the pre-production environment.

Findings are based on the information, documents and demonstrations provided during the audit period. The audit is sample-based: it does not guarantee the absence of other gaps. Framework mappings are indicative and do not constitute a compliance attestation.

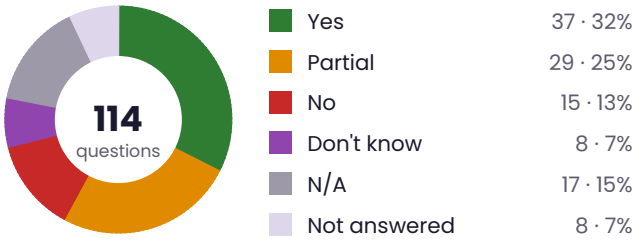
5. Overall results

5.1 Figures at a glance

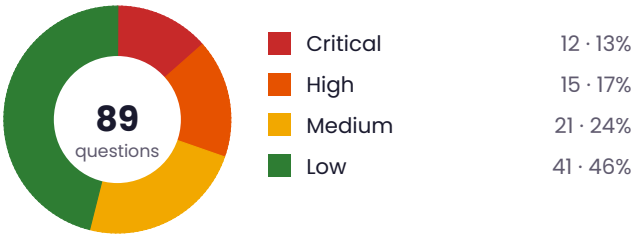
Domain	Applicable	Answered	Compliance	Gaps
AI governance and organisation	12	12	73%	5
Inventory of AI use and shadow AI	8	8	58%	5
LLM models and supply chain	8	7	67%	4
Data and privacy	10	8	63%	5
Prompts, inputs / outputs and RAG	12	12	54%	6
AI agents and autonomy	14	13	50%	10
AI workflows and integrations (MCP, API, A2A)	12	10	33%	5
Testing, red teaming and evaluation	10	9	53%	6
Monitoring, logging and incidents	11	10	47%	6
Regulation and compliance	6	6	100%	0
Total	103	95	58%	52

5.2 Breakdown of answers and risks

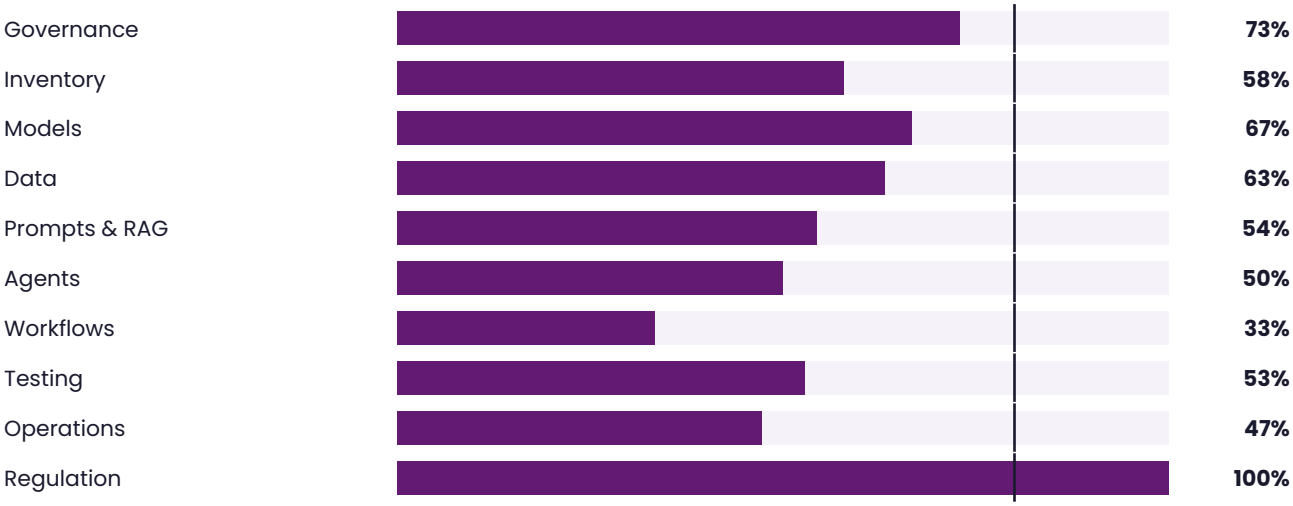
Answer breakdown



Residual risks by level



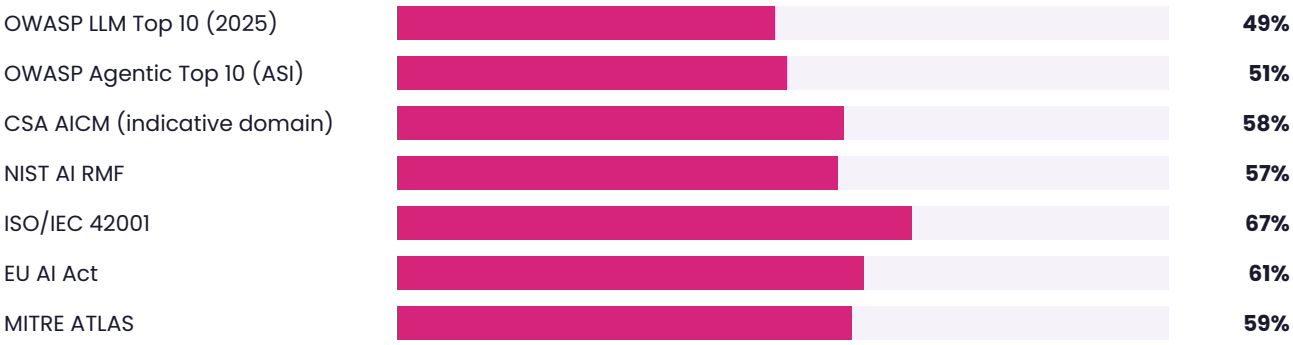
5.3 Compliance by domain



Vertical mark: 80% target.



5.4 Compliance by framework



Indicative mappings: they guide the analysis and do not replace reading the official texts.

5.5 Residual risk matrix

Impact / Likelihood	1	2	3	4	5
5 Major	12	6	0	6	0
4 High	26	2	3	6	0
3 Moderate	15	5	1	6	0
2 Low	0	0	0	1	0
1 Minor	0	0	0	0	0

Rows: impact • columns: residual likelihood • number of questions per cell.

6. Detailed results by domain

6.1 AI governance and organisation

Compliance 73% • 12 applicable • 5 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
GOV-01	Is an AI acceptable-use policy documented, approved by management and communicated?	Partial	Document review	8 Medium	
GOV-02	Has an owner for AI security and governance been appointed?	Partial	Interview	4 Low	
GOV-03	Does each AI system have an identified, accountable business owner?	Yes	Technical test	3 Low	
GOV-04	Is a risk assessment performed before any AI system goes live?	Yes	Document review	5 Medium	
GOV-05	Is an impact assessment on people and society carried out for sensitive uses?	Yes	Interview	4 Low	
GOV-06	Are permitted levels of AI autonomy defined according to risk?	Partial	Document review	10 High	
GOV-07	Are staff trained on AI risks and proper use?	Yes	Interview	3 Low	
GOV-08	Are AI vendors assessed (security, data location, contracts) before signing?	N/A	Technical test	—	
GOV-09	Is AI security part of the same incident process as cybersecurity?	Partial	Document review	4 Low	
GOV-10	Are AI risk indicators tracked and reported to management?	Yes	Interview	3 Low	
GOV-11	Have insurance policies been reviewed for AI-related exclusions?	Yes	Document review	4 Low	
GOV-12	Is there a decommissioning process for AI systems?	Don't know	Interview	9 Medium	

6.2 Inventory of AI use and shadow AI

Compliance 58% • 8 applicable • 5 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
INV-01	Is a central register of all AI systems, models and agents kept up to date?	No	Technical test	16 Critical	
INV-02	Is the use of unapproved AI tools (shadow AI) detected?	Yes	Document review	4 Low	
INV-03	Is a list of approved AI tools published and offered as an alternative?	Partial	Interview	6 Medium	
INV-04	Are permissions granted by employees to third-party AI apps (OAuth) controlled?	Yes	Document review	5 Medium	
INV-05	Are AI features embedded in existing software (SaaS, office suites) inventoried?	No	Interview	12 High	
INV-06	Is each AI system classified by risk level?	Yes	Technical test	4 Low	
INV-07	Is the organisation's AI adoption tier known (from embedded assistant to cross-organisation agents)?	No	Document review	12 High	

ID	Question	Answer	Verification method	Risk	Evidence / finding
INV-08	Are the components of each system (models, libraries, prompts, tools) inventoried (AI SBOM)?	Partial	Interview	4 Low	

6.3 LLM models and supply chain

Compliance 67% • 8 applicable • 4 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
MOD-01	Do the models in use come from verified and approved sources?	Yes	Document review	5 Medium	
MOD-02	Are model files loaded in safe formats (safetensors, GGUF) rather than pickle?	N/A	Interview	—	
MOD-03	Does an admission process validate each new model before production?	N/A	—	—	
MOD-04	Are training or fine-tuning datasets checked against poisoning?	N/A	—	—	
MOD-05	Are model weights and inference endpoints protected against theft?	N/A	Interview	—	
MOD-06	Are model versions pinned and every version change tested?	Partial	Document review	6 Medium	
MOD-07	Is the choice between self-hosted and cloud models justified by data sensitivity?	Not answered	—	—	
MOD-08	Are known model limitations (hallucinations, bias, weak domains) documented?	Yes	Technical test	3 Low	
MOD-09	Are models evaluated for robustness (adversarial attacks, jailbreaks)?	Partial	Document review	4 Low	
MOD-10	Is resource consumption (tokens, GPU, cost) capped?	No	Interview	12 High	
MOD-11	Is the right model chosen for each task (a small model when sufficient)?	No	Document review	8 Medium	
MOD-12	Are extensions, plugins and skills loaded by models verified?	Yes	Interview	5 Medium	

6.4 Data and privacy

Compliance 63% • 10 applicable • 5 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
DAT-01	Is data sent to models classified (public, internal, confidential)?	Yes	Technical test	4 Low	
DAT-02	Does a control prevent sensitive data being sent to external AI services (DLP)?	Not answered	—	—	
DAT-03	Is data minimisation applied to personal data processed by AI?	Partial	Interview	4 Low	
DAT-04	Is a data protection impact assessment (DPIA) performed for risky AI processing?	Yes	Document review	4 Low	
DAT-05	Do contracts guarantee the vendor does not use your data to train its models?	No	Interview	16 Critical	
DAT-06	Are retention periods defined for prompts, responses and AI logs?	Partial	Technical test	6 Medium	

ID	Question	Answer	Verification method	Risk	Evidence / finding
DAT-07	Are people informed when their data is processed by AI?	Yes	Document review	3 Low	
DAT-08	Is training data documented (origin, licences, quality, bias)?	N/A	Interview	—	
DAT-09	Is data processed by AI encrypted in transit and at rest?	Partial	Document review	4 Low	
DAT-10	Are privacy-enhancing techniques considered (anonymisation, synthetic data, differential privacy)?	Partial	Interview	3 Low	
DAT-11	Are model data-leakage risks (memorisation, membership inference) assessed?	N/A	Technical test	—	
DAT-12	Are data transfers outside the EU by AI services identified and governed?	Not answered	—	—	

6.5 Prompts, inputs / outputs and RAG

Compliance 54% • 12 applicable • 6 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
PRM-01	Are user inputs filtered against prompt injection?	Yes	Interview	5 Medium	
PRM-02	Is external content read by AI (web pages, e-mails, documents) treated as untrusted?	N/A	Document review	—	
PRM-03	Are AI outputs validated before being executed or displayed?	Partial	Interview	10 High	
PRM-04	Is the system prompt free of secrets (passwords, keys, critical security rules)?	Yes	Technical test	4 Low	
PRM-05	Are responses filtered to prevent disclosure of sensitive data?	No	Document review	16 Critical	
PRM-06	Are document access rights enforced in RAG retrieval?	Partial	Interview	10 High	
PRM-07	Are documents added to the RAG store checked (origin, malicious content)?	Don't know	Document review	16 Critical	
PRM-08	Are vector stores segregated by client or sensitivity level?	No	Interview	12 High	
PRM-09	Do responses cite their sources so they can be verified?	Yes	Technical test	3 Low	
PRM-10	Are system prompts and prompt templates versioned and reviewed?	Yes	Document review	3 Low	
PRM-11	Are users warned that AI answers may be wrong?	Partial	Interview	6 Medium	
PRM-12	Are request length and volume limited?	Yes	Document review	3 Low	

6.6 AI agents and autonomy

Compliance 50% • 14 applicable • 10 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
AGT-01	Does each agent have its own identity, separate from human and shared accounts?	Yes	Interview	5 Medium	
AGT-02	Do agents use short-lived credentials instead of permanent keys?	Partial	Technical test	10 High	
AGT-03	Are agent permissions limited to the strict minimum for each task?	No	Document review	20 Critical	
AGT-04	Do high-impact actions (payment, deletion, external sending) require human approval?	No	Interview	20 Critical	
AGT-05	Can a kill switch stop an agent within seconds?	Not answered	Technical test	—	Manual token revocation, tested in March
AGT-06	Does each agent action also carry the identity of the person who made the request?	Partial	Interview	4 Low	
AGT-07	Does code generated or run by agents execute in an isolated sandbox?	Partial	Technical test	10 High	
AGT-08	Are the agent's protections out of its reach (it cannot change its own guardrails)?	Partial	Document review	5 Medium	
AGT-09	Is agent memory protected against poisoning and segregated per user?	Partial	Interview	4 Low	
AGT-10	Are agent goals and plans monitored to detect hijacking?	Don't know	Document review	20 Critical	
AGT-11	Are agent-to-agent communications authenticated and encrypted?	Partial	Interview	4 Low	
AGT-12	Do limits prevent cascading failures (loops, budgets, number of steps)?	Partial	Technical test	4 Low	
AGT-13	Are agents created for a task deleted, with their access, once the task is done?	Yes	Document review	4 Low	
AGT-14	Do coding agents have specific guardrails (no direct production deployment, review)?	Yes	Interview	5 Medium	

6.7 AI workflows and integrations (MCP, API, A2A)

Compliance 33% • 12 applicable • 5 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
WFL-01	Are MCP servers, APIs and tools connected to agents inventoried and approved?	Don't know	Document review	20 Critical	
WFL-02	Are tool access tokens scoped to one resource and limited in time (OAuth 2.1)?	Yes	Interview	5 Medium	
WFL-03	Are tool descriptions and definitions protected against malicious changes?	Yes	Technical test	5 Medium	
WFL-04	Are parameters sent to tools validated before execution?	Don't know	Document review	20 Critical	
WFL-05	Do local or third-party MCP servers run with reduced privileges?	N/A	Interview	—	
WFL-06	Are agent directories and agent cards (A2A discovery) verified before trusting a third-party agent?	Not answered	—	—	

ID	Question	Answer	Verification method	Risk	Evidence / finding
WFL-07	Are automated AI workflows (no-code, low-code) reviewed by security?	Not answered	—	—	
WFL-08	Are workflow secrets stored in a vault rather than in code or prompts?	N/A	Technical test	—	
WFL-09	Are agents in CI/CD pipelines protected against untrusted external content (tickets, pull requests)?	Don't know	Document review	20 Critical	
WFL-10	Are updates of MCP servers and tools controlled (pinned version, verification)?	No	Interview	12 High	
WFL-11	Are data flows between AI and business systems mapped?	No	Document review	12 High	
WFL-12	Is a degraded mode planned if the model or a tool becomes unavailable?	Yes	Interview	3 Low	

6.8 Testing, red teaming and evaluation

Compliance 53% • 10 applicable • 6 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
TST-01	Are attack tests (red teaming) carried out before production?	Partial	Technical test	10 High	
TST-02	Do tests cover all ten risks of the OWASP Agentic Top 10?	Partial	Document review	8 Medium	
TST-03	Are automated evaluation suites run at every model, prompt or tool change?	Yes	Interview	4 Low	
TST-04	Is answer quality (accuracy, hallucinations) measured with indicators?	Partial	Document review	6 Medium	
TST-05	Are bias and fairness evaluated for uses affecting people?	No	Interview	12 High	
TST-06	Do AI-generated applications (vibe coding) undergo a security review?	Don't know	Technical test	16 Critical	
TST-07	Are vulnerabilities in AI components tracked and fixed (CVE monitoring)?	Yes	Document review	4 Low	
TST-08	Are tests repeated regularly after go-live?	Not answered	—	—	
TST-09	Is an independent audit of critical AI systems planned?	Yes	Document review	3 Low	
TST-10	Are the kill switch and AI incident procedure tested through exercises?	Partial	Interview	4 Low	

6.9 Monitoring, logging and incidents

Compliance 47% • 11 applicable • 6 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
OPS-01	Is every AI interaction and action logged?	No	Technical test	16 Critical	
OPS-02	Are logs protected against tampering?	Partial	Document review	4 Low	
OPS-03	Are AI logs sent to the SIEM and analysed by the SOC?	Yes	Interview	4 Low	

ID	Question	Answer	Verification method	Risk	Evidence / finding
OPS-04	Do alerts detect abnormal behaviour of agents or models?	Not answered	—	—	
OPS-05	Is there an incident response procedure specific to AI?	Partial	Interview	5 Medium	
OPS-06	Can an incident be reported within regulatory deadlines (4 h DORA, 24 h NIS2)?	N/A	Technical test	—	
OPS-07	Are AI system performance and quality monitored continuously?	No	Document review	12 High	
OPS-08	Is a fast rollback to a previous version (model, prompt, tool) possible?	Partial	Interview	4 Low	
OPS-09	Can users easily report a problematic answer or action?	Yes	Document review	3 Low	
OPS-10	Are AI costs and consumption tracked to detect abuse?	Don't know	Interview	12 High	
OPS-11	Do logs allow an incident to be reconstructed precisely?	N/A	Technical test	—	
OPS-12	Does a continuity plan cover the unavailability of an AI provider?	Yes	Document review	3 Low	

6.10 Regulation and compliance

Compliance 100% • 6 applicable • 0 gaps

ID	Question	Answer	Verification method	Risk	Evidence / finding
REG-01	Have the EU AI Act obligations applicable to the organisation been identified?	Yes	Interview	4 Low	
REG-02	Is no practice prohibited by the EU AI Act in use?	Yes	Document review	5 Medium	
REG-03	Is technical documentation of high-risk systems kept up to date?	N/A	Interview	—	
REG-04	Is effective human oversight organised for high-risk systems?	N/A	Technical test	—	
REG-05	Is a post-market monitoring plan in place?	N/A	Document review	—	
REG-06	Are users informed that they are interacting with AI or AI-generated content?	N/A	Interview	—	
REG-07	Are GDPR requirements built into AI projects by design?	Yes	Document review	4 Low	
REG-08	Are sector requirements (DORA, NIS2) applied to AI systems?	N/A	Interview	—	
REG-09	Does the organisation follow or target an AI management system (ISO/IEC 42001)?	Yes	Technical test	3 Low	
REG-10	Are mappings between internal controls and frameworks (NIST, ISO, AICM) maintained?	Yes	Document review	3 Low	

7. Risk register and action plan

7.1 Risk register

ID	Domain	Question	Answer	Risk	Level
AGT-03	Agents	Are agent permissions limited to the strict minimum for each task?	No	20	Critical
AGT-04	Agents	Do high-impact actions (payment, deletion, external sending) require human approval?	No	20	Critical
WFL-01	Workflows	Are MCP servers, APIs and tools connected to agents inventoried and approved?	Don't know	20	Critical
WFL-04	Workflows	Are parameters sent to tools validated before execution?	Don't know	20	Critical
AGT-10	Agents	Are agent goals and plans monitored to detect hijacking?	Don't know	20	Critical
WFL-09	Workflows	Are agents in CI/CD pipelines protected against untrusted external content (tickets, pull requests)?	Don't know	20	Critical
INV-01	Inventory	Is a central register of all AI systems, models and agents kept up to date?	No	16	Critical
DAT-05	Data	Do contracts guarantee the vendor does not use your data to train its models?	No	16	Critical
PRM-05	Prompts & RAG	Are responses filtered to prevent disclosure of sensitive data?	No	16	Critical
OPS-01	Operations	Is every AI interaction and action logged?	No	16	Critical
PRM-07	Prompts & RAG	Are documents added to the RAG store checked (origin, malicious content)?	Don't know	16	Critical
TST-06	Testing	Do AI-generated applications (vibe coding) undergo a security review?	Don't know	16	Critical
PRM-08	Prompts & RAG	Are vector stores segregated by client or sensitivity level?	No	12	High
WFL-10	Workflows	Are updates of MCP servers and tools controlled (pinned version, verification)?	No	12	High
TST-05	Testing	Are bias and fairness evaluated for uses affecting people?	No	12	High
INV-05	Inventory	Are AI features embedded in existing software (SaaS, office suites) inventoried?	No	12	High
MOD-10	Models	Is resource consumption (tokens, GPU, cost) capped?	No	12	High
WFL-11	Workflows	Are data flows between AI and business systems mapped?	No	12	High
OPS-07	Operations	Are AI system performance and quality monitored continuously?	No	12	High
INV-07	Inventory	Is the organisation's AI adoption tier known (from embedded assistant to cross-organisation agents)?	No	12	High
OPS-10	Operations	Are AI costs and consumption tracked to detect abuse?	Don't know	12	High
GOV-06	Governance	Are permitted levels of AI autonomy defined according to risk?	Partial	10	High
PRM-03	Prompts & RAG	Are AI outputs validated before being executed or displayed?	Partial	10	High
PRM-06	Prompts & RAG	Are document access rights enforced in RAG retrieval?	Partial	10	High
AGT-02	Agents	Do agents use short-lived credentials instead of permanent keys?	Partial	10	High

ID	Domain	Question	Answer	Risk	Level
AGT-07	Agents	Does code generated or run by agents execute in an isolated sandbox?	Partial	10	High
TST-01	Testing	Are attack tests (red teaming) carried out before production?	Partial	10	High
GOV-12	Governance	Is there a decommissioning process for AI systems?	Don't know	9	Medium
GOV-01	Governance	Is an AI acceptable-use policy documented, approved by management and communicated?	Partial	8	Medium
TST-02	Testing	Do tests cover all ten risks of the OWASP Agentic Top 10?	Partial	8	Medium
MOD-11	Models	Is the right model chosen for each task (a small model when sufficient)?	No	8	Medium
INV-03	Inventory	Is a list of approved AI tools published and offered as an alternative?	Partial	6	Medium
MOD-06	Models	Are model versions pinned and every version change tested?	Partial	6	Medium
DAT-06	Data	Are retention periods defined for prompts, responses and AI logs?	Partial	6	Medium
TST-04	Testing	Is answer quality (accuracy, hallucinations) measured with indicators?	Partial	6	Medium
PRM-11	Prompts & RAG	Are users warned that AI answers may be wrong?	Partial	6	Medium
AGT-08	Agents	Are the agent's protections out of its reach (it cannot change its own guardrails)?	Partial	5	Medium
OPS-05	Operations	Is there an incident response procedure specific to AI?	Partial	5	Medium
GOV-02	Governance	Has an owner for AI security and governance been appointed?	Partial	4	Low
DAT-03	Data	Is data minimisation applied to personal data processed by AI?	Partial	4	Low
GOV-09	Governance	Is AI security part of the same incident process as cybersecurity?	Partial	4	Low
INV-08	Inventory	Are the components of each system (models, libraries, prompts, tools) inventoried (AI SBOM)?	Partial	4	Low
MOD-09	Models	Are models evaluated for robustness (adversarial attacks, jailbreaks)?	Partial	4	Low
DAT-09	Data	Is data processed by AI encrypted in transit and at rest?	Partial	4	Low
AGT-06	Agents	Does each agent action also carry the identity of the person who made the request?	Partial	4	Low
AGT-09	Agents	Is agent memory protected against poisoning and segregated per user?	Partial	4	Low
AGT-11	Agents	Are agent-to-agent communications authenticated and encrypted?	Partial	4	Low
AGT-12	Agents	Do limits prevent cascading failures (loops, budgets, number of steps)?	Partial	4	Low
TST-10	Testing	Are the kill switch and AI incident procedure tested through exercises?	Partial	4	Low
OPS-02	Operations	Are logs protected against tampering?	Partial	4	Low
OPS-08	Operations	Is a fast rollback to a previous version (model, prompt, tool) possible?	Partial	4	Low
DAT-10	Data	Are privacy-enhancing techniques considered (anonymisation, synthetic data, differential privacy)?	Partial	3	Low

7.2 Action plan

Priorities: P1 = critical risk, address within 3 months; P2 = high, within 6 months; P3 = medium, within 12 months; P4 = low, continual improvement.

ID	Action	Owner	Due date	Priority
AGT-03	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P1
AGT-04	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P1
WFL-01	To be defined — Inventory and approve connected tools, scope tokens and validate parameters sent to tools.	To be defined	To be defined	P1
WFL-04	To be defined — Inventory and approve connected tools, scope tokens and validate parameters sent to tools.	To be defined	To be defined	P1
AGT-10	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P1
WFL-09	To be defined — Inventory and approve connected tools, scope tokens and validate parameters sent to tools.	To be defined	To be defined	P1
INV-01	To be defined — Build a central register of AI systems and agents and detect unapproved use.	To be defined	To be defined	P1
DAT-05	To be defined — Classify data, prevent leakage to external services and apply GDPR by design.	To be defined	To be defined	P1
PRM-05	To be defined — Deploy input and output guardrails against prompt injection and data disclosure.	To be defined	To be defined	P1
OPS-01	To be defined — Log every AI action in a tamper-proof way, send it to the SOC and prepare incident response.	To be defined	To be defined	P1
PRM-07	To be defined — Deploy input and output guardrails against prompt injection and data disclosure.	To be defined	To be defined	P1
TST-06	To be defined — Run regular attack testing covering OWASP risks, plus automated evaluations.	To be defined	To be defined	P1
PRM-08	To be defined — Deploy input and output guardrails against prompt injection and data disclosure.	To be defined	To be defined	P2
WFL-10	To be defined — Inventory and approve connected tools, scope tokens and validate parameters sent to tools.	To be defined	To be defined	P2
TST-05	To be defined — Run regular attack testing covering OWASP risks, plus automated evaluations.	To be defined	To be defined	P2
INV-05	To be defined — Build a central register of AI systems and agents and detect unapproved use.	To be defined	To be defined	P2
MOD-10	To be defined — Govern model provenance, admission and robustness, including extensions.	To be defined	To be defined	P2
WFL-11	To be defined — Inventory and approve connected tools, scope tokens and validate parameters sent to tools.	To be defined	To be defined	P2
OPS-07	To be defined — Log every AI action in a tamper-proof way, send it to the SOC and prepare incident response.	To be defined	To be defined	P2
INV-07	To be defined — Build a central register of AI systems and agents and detect unapproved use.	To be defined	To be defined	P2
OPS-10	To be defined — Log every AI action in a tamper-proof way, send it to the SOC and prepare incident response.	To be defined	To be defined	P2
GOV-06	To be defined — Formalise the AI policy, appoint owners and embed risk assessment in every go-live.	To be defined	To be defined	P2
PRM-03	To be defined — Deploy input and output guardrails against prompt injection and data disclosure.	To be defined	To be defined	P2

ID	Action	Owner	Due date	Priority
PRM-06	To be defined — Deploy input and output guardrails against prompt injection and data disclosure.	To be defined	To be defined	P2
AGT-02	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P2
AGT-07	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P2
TST-01	To be defined — Run regular attack testing covering OWASP risks, plus automated evaluations.	To be defined	To be defined	P2
GOV-12	To be defined — Formalise the AI policy, appoint owners and embed risk assessment in every go-live.	To be defined	To be defined	P3
GOV-01	To be defined — Formalise the AI policy, appoint owners and embed risk assessment in every go-live.	To be defined	To be defined	P3
TST-02	To be defined — Run regular attack testing covering OWASP risks, plus automated evaluations.	To be defined	To be defined	P3
MOD-11	To be defined — Govern model provenance, admission and robustness, including extensions.	To be defined	To be defined	P3
INV-03	To be defined — Build a central register of AI systems and agents and detect unapproved use.	To be defined	To be defined	P3
MOD-06	To be defined — Govern model provenance, admission and robustness, including extensions.	To be defined	To be defined	P3
DAT-06	To be defined — Classify data, prevent leakage to external services and apply GDPR by design.	To be defined	To be defined	P3
TST-04	To be defined — Run regular attack testing covering OWASP risks, plus automated evaluations.	To be defined	To be defined	P3
PRM-11	To be defined — Deploy input and output guardrails against prompt injection and data disclosure.	To be defined	To be defined	P3
AGT-08	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P3
OPS-05	To be defined — Log every AI action in a tamper-proof way, send it to the SOC and prepare incident response.	To be defined	To be defined	P3
GOV-02	To be defined — Formalise the AI policy, appoint owners and embed risk assessment in every go-live.	To be defined	To be defined	P4
DAT-03	To be defined — Classify data, prevent leakage to external services and apply GDPR by design.	To be defined	To be defined	P4
GOV-09	To be defined — Formalise the AI policy, appoint owners and embed risk assessment in every go-live.	To be defined	To be defined	P4
INV-08	To be defined — Build a central register of AI systems and agents and detect unapproved use.	To be defined	To be defined	P4
MOD-09	To be defined — Govern model provenance, admission and robustness, including extensions.	To be defined	To be defined	P4
DAT-09	To be defined — Classify data, prevent leakage to external services and apply GDPR by design.	To be defined	To be defined	P4
AGT-06	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P4
AGT-09	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P4
AGT-11	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P4
AGT-12	To be defined — Give agents their own identity, limit their rights, sandbox their execution and provide a kill switch.	To be defined	To be defined	P4

ID	Action	Owner	Due date	Priority
TST-10	To be defined — Run regular attack testing covering OWASP risks, plus automated evaluations.	To be defined	To be defined	P4
OPS-02	To be defined — Log every AI action in a tamper-proof way, send it to the SOC and prepare incident response.	To be defined	To be defined	P4
OPS-08	To be defined — Log every AI action in a tamper-proof way, send it to the SOC and prepare incident response.	To be defined	To be defined	P4
DAT-10	To be defined — Classify data, prevent leakage to external services and apply GDPR by design.	To be defined	To be defined	P4

8. Conclusion

8.1 Auditor's conclusion

> The set-up is defined and covers a significant share of the requirements. Material gaps remain in some domains. Implementing the action plan would bring the organisation to a managed level.

Overall compliance: 58% • Maturity: 2 — Defined • Critical 12 • High 15 • Medium 21 • Low 41

8.2 Next steps

- Approve the action plan with management and assign an owner to each action.
- Address P1 actions within three months and track progress monthly.
- Keep implementation evidence for the next review.
- Perform a follow-up audit within twelve months, or after any major change to AI systems.

9. Approval and distribution

9.1 Approval

Role	Name and title	Date	Signature
Lead auditor	Lead auditor (example)		
Audited entity representative	Chief Information Security Officer		

9.2 Distribution list

This report is classified "Confidential". Its distribution is limited to the following recipients:

- CISO
- CIO
- AI programme lead
- DPO

Appendices

Appendix A — Organisation profile

Profile question	Answer
Do you use (or plan to use) AI agents able to act: call tools or APIs, run code?	Yes
Do your AI agents or workflows connect to external tools (MCP, third-party APIs, A2A, plugins)?	Yes
Do you use document stores queried by AI (RAG, vector databases)?	Yes
Do you host, train or fine-tune your own models?	No
Do your AI systems process personal data?	Yes
Is any of your systems high-risk under the EU AI Act, or subject to DORA / NIS2?	No

Appendix B — Glossary

AI agent	AI system that plans and acts with tools to reach a goal.
AI SBOM	Inventory of an AI system's components and their origin.
Kill switch	Mechanism that stops an agent immediately.
Prompt injection	Malicious instruction hidden in content read by the AI.
MCP	Model Context Protocol: standard protocol for plugging tools into an agent.
RAG	Retrieval-augmented generation from a document base.
Residual risk	Risk remaining given the measures in place.
Shadow AI	Use of AI tools without organisational approval.

Appendix C — Disclaimer

This report was prepared from a structured questionnaire and the evidence provided by the audited entity during the audit period. It reflects the situation observed at that date.

It is neither a certification, nor legal advice, nor a security guarantee. Mappings to frameworks (NIST, ISO/IEC, OWASP, CSA, MITRE, EU regulation) are indicative.

Trademarks and framework names cited belong to their respective owners and do not imply any endorsement of this report.